Gap Analysis — Acredittia

Estado: borrador de revisión Fecha de referencia: 13-10-2026

Este documento consolida la evidencia documental y técnica del proyecto a partir de la especificación funcional (SRS.md) y la implementación actual en código, sin ejecutar pruebas ni arranques. Su objetivo es dejar un resumen claro, útil para revisión interna y para conversión a PDF.

1. Propósito

Este documento complementa al SRS y al plan operativo. Su objetivo es resumir las brechas funcionales, de seguridad, de auditoría y de producto que aún no están cerradas antes de considerar la consola administrativa como un módulo listo para producción.

No reemplaza el SRS. Sirve como registro de evidencia y de decisiones pendientes para cerrar requisitos, riesgos y pruebas.

2. Método

Se compararon tres fuentes:

- Requisitos funcionales del SRS y de la matriz de administración.
- Evidencia funcional implementada en la API y en el frontend.
- Decisiones pendientes o no aprobadas registradas en documentación y conversaciones de producto.

La evaluación no se basa solo en la existencia de pantallas. Se prioriza la evidencia de cumplimiento por criterios de aceptación, autorización, auditoría, aislamiento de datos y validación operativa.

3. Resumen ejecutivo

Actualización 13-10-2026: además de las mejoras recientes de interfaz y trazabilidad, se revisaron el código y la documentación de las ocho prioridades ADMIN. La revisión estima **67% de avance funcional ADMIN** como promedio simple de estimaciones por prioridad: 75%, 90%, 55%, 60%, 70%, 70%, 50% y 62%. No se ejecutaron pruebas ni recorrido de navegador para producir esta estimación; no equivale a cumplimiento validado ni a preparación para producción. Los bloqueos P0 de DEC-08, permisos granulares, auditoría integral y evidencia de aislamiento/mínimo privilegio siguen abiertos.

El módulo admin tiene una base funcional sólida en:

- dashboard general y KPI operativos,
- gestión global de empresas,
- listado y control de usuarios,
- búsqueda global básica,
- alertas en empresa y contratos,
- auditoría de actividades relevantes,
- políticas de aislamiento por tenant y roles.

Sin embargo, todavía existen brechas importantes en:

- permisos granulares por categoría y por recurso,
- auditoría completa de accesos sensibles, descargas y exportaciones,
- acceso excepcional mínimo necesario para documentos sensibles,
- definición de métricas SaaS y de salud con universos claros,
- gestión multiempresa / alcance de cuenta entre entidades,
- validación de entorno de producción y control de exportaciones/restauración.

El estado global es mejor que un prototipo, pero no alcanza la madurez de producción sin cerrar esas brechas.

La principal señal de riesgo es el bloqueo P0 documentado en el SRS:

- No pasar a producción con datos reales sin cerrar DEC-08.
- Requiere evidencia legal/contractual, aprobación de retención, responsables y controles implementados/validados.

En términos prácticos, la cifra actual de 67% corresponde únicamente a avance funcional estimado de ADMIN. No se calcula un porcentaje de preparación para producción real con datos sensibles: los bloqueos existentes impiden interpretar el avance funcional como autorización de despliegue. Las cifras 75–80% general y 55–65% para producción que aparecían en cortes anteriores son históricas y no deben utilizarse como estimaciones vigentes.

4. Fuentes de evidencia utilizadas

- SRS.md — requisitos, prioridades, estados, bloqueos y criterios.
- README.md — contexto general del proyecto y observaciones operativas.
- README_ops_Back.md — trazabilidad de la consola interna backend.
- BASE/app/backend/app/main.py — arranque API y guardas de seguridad.
- BASE/app/backend/app/config.py — configuración de producción y validaciones.
- BASE/app/backend/app/routers/admin.py — administración global.
- BASE/app/backend/app/routers/admin_ops.py — consola interna y métricas.
- BASE/app/backend/worker/ops_tasks.py — jobs, health y operación.

5. Matriz de cumplimiento por prioridad de ADMIN

Prioridad	Estado	% estimado al 13-10-2026	Observación
Dashboard global	Parcial	75%	Hay contadores, acreditación, estados documentales y actividad por eventos; falta validar universos/denominadores y crecimiento de adopción.
Gestión global de empresas	Avanzado	90%	Listado y ficha agregada con industria, estado de cuenta, perfiles y responsables; el rechazo y los casos límite siguen pendientes.
Buscador global	Parcial	55%	Las categorías están implementadas, pero la autorización por categoría y detalle no se aplica como permiso granular en servidor.

Prioridad	Estado	% estimado al 13-10-2026	Observación
Métricas SaaS	Parcial	60%	Existen métricas y series; tiempo de uso continúa estimado, y documentos procesados no equivale necesariamente a documentos únicos. Faltan definiciones y cálculos validados.
Alertas y salud de clientes	Parcial	70%	Hay indicadores y detalle plegable; faltan validar umbrales, casos límite, totales/paginación y sondas que acrediten disponibilidad real.
Usuarios, roles y permisos	Parcial	70%	Hay roles y alcances empresa/contrato e invalidación de sesiones; faltan altas/invitaciones, navegación sobre 100 usuarios, historial completo y validación integral.
Auditoría y trazabilidad	Parcial	50%	Algunas operaciones y descargas quedan registradas; falta cobertura uniforme de autenticación, lecturas sensibles, operaciones y transferencias de exportación.
Seguridad y aislamiento de datos	Parcial; bloqueo P0	62%	Hay autorización, RLS y pruebas multiempresa; falta demostrar mínimo privilegio y aislamiento contractual con configuración equivalente a producción, además de acceso excepcional auditado.

% global estimado

El **67%** es el promedio simple de las ocho estimaciones de avance funcional ADMIN: `(75 + 90 + 55 + 60 + 70 + 70 + 50 + 62) / 8 = 66,5%`, redondeado al entero más cercano. Las prioridades tienen igual peso por falta de ponderación acordada. La revisión fue documental y de código; no ejecutó pruebas ni recorrido de navegador. No es cumplimiento validado ni porcentaje de preparación productiva.

Indicador	Valor
Avance funcional ADMIN estimado	67%
Preparación para producción real con datos sensibles	No puntuada; bloqueada por brechas P0 y DEC-08
Cumplimiento ADMIN validado como conjunto	No determinado; aceptación integral pendiente
Estado del riesgo crítico operativo	Alto; no expresado como porcentaje de avance

Conclusión global: ADMIN cuenta con una base funcional avanzada, pero el 67% no significa que esté listo para producción real. Permanecen brechas críticas de permisos granulares, aislamiento/mínimo privilegio, auditoría y revisión legal/retención.

6. Brechas por prioridad

6.1 Dashboard global

Estado: parcial.

Cumple parcialmente:

- cuentas de empresas, contratos, trabajadores y usuarios;
- porcentaje de acreditación global;
- documentos pendientes/vencidos;
- actividad y crecimiento visible.

Brechas:

- falta acuerdo explícito sobre universos y denominadores de cada KPI;
- necesidad de distinguir "actividad" de "crecimiento de clientes" y "adopción";
- algunos indicadores dependen de series o eventos no normalizados aún;
- falta validación de definiciones de venta/uso, especialmente para métricas SaaS.

Riesgo:

- reportes incorrectos o comparaciones engañosas entre paneles.

6.2 Gestión global de empresas

Estado: principalmente funcional en lectura y control administrativo.

Cumple parcialmente:

- listado de empresas;
- estado de cada cliente;
- número de contratos y trabajadores;
- nivel de uso y última actividad;
- ocultación de datos sensibles innecesarios en listados.

Brechas:

- falta validación completa de rechazos, transiciones y flujo de aprobación de registro;
- quedan pendientes decisiones sobre empresas multi-contrato y sobre la representación de flujo comercial vs operativo;
- la industria y el estado de cuenta ya se muestran en la tabla y el detalle agregado incluye perfiles/responsables; esto no reemplaza la diferenciación entre detalle operativo y detalle comercial ni valida la exactitud de los estados de pago.

Riesgo:

- decisiones orientadas a la administración sin distinguir claramente compradores, empresas, usuarios, contratos y obligaciones.

6.3 Buscador global

Estado: funcional pero con brecha de cumplimiento de permisos.

Cumple parcialmente:

- búsqueda por empresa, contrato, trabajador, equipo y usuario;
- filtros y referencias por categorías;

- panel de resultados con control por categoría.

Brechas:

- la interfaz ahora agrupa la exploración por botones de categoría, pero la validación de permisos por tipo de información aún es incompleta en el backend;
- el buscador despliega permisos y referencias, pero no garantiza aislamiento por recurso en todas las rutas;
- no queda completamente cerrado el criterio de visibilidad de detalle por empresa/contrato/usuario.

Riesgo:

- un usuario con acceso limitado podría inferir información fuera de su alcance, o el cliente podría ver registros sensibles por abuso de flujo o de filtros.

6.4 Métricas SaaS

Estado: parcial.

Cumple parcialmente:

- empresas activas;
- usuarios activos;
- sesiones;
- tiempo de uso;
- documentos procesados;
- evolución mensual;
- identificación de clientes con baja actividad, presentada ahora en Salud de clientes.

Brechas:

- tiempo de uso aún no está basado en telemetría real del producto;
- faltan definiciones de ventana temporal y denominadores consentidos;
- no está cerrada la fuente de sesión/uso ni la lógica de actividad productiva;
- la validación de crecimiento y series positivas/negativas no está completamente cerrada. Los indicadores de uso/adopción y la distribución de usuarios por plan/industria ahora se presentan en Salud de clientes, no en esta vista.

Riesgo:

- métricas no auditables ni comparables entre períodos.

6.5 Alertas y salud de clientes

Estado: parcial.

Cumple parcialmente:

- alertas de acreditación y vencimientos;
- alertas por documentación pendiente;
- salud de clientes y listado de incidentes;
- panel de salud con alertas activas;

- indicadores de uso/adopción, clientes con baja actividad y usuarios por plan/industria, con detalle desplegable.

Brechas:

- faltan umbrales explícitos para baja actividad, muchos pendientes y vencimientos;
- falta distinguir claramente empresa sin usuarios, empresa con usuarios sin actividad, empresa sin documentos y salud correcta;
- los totales y paginación de bandeja requieren validación en casos límite;
- no está cerrada la prueba de salud real con API/worker/DB. La vista ya resume riesgos por categoría y despliega el detalle; las ayudas explicativas no sustituyen la verificación de datos y reglas.

Riesgo:

- falsas alarmas o alarmas no accionables, con impacto operativo.

6.6 Usuarios, roles y permisos

Estado: funcional en parte, pero incompleto.

Cumple parcialmente:

- roles admin, company y contract_admin;
- asignación de empresa y contrato;
- revocación y reactivación de acceso;
- registro de último acceso;
- invalidación de sesiones al cambiar permisos.
- ajuste aplicado: desde la ficha de empresa del admin se muestran las cuentas asociadas, su perfil, rol y responsable de contrato para facilitar la gestión y la auditoría sin ocultar datos necesarios a la administración global.

Brechas:

- no existe una invitación formal ni flujo de aprobación de membresía a una empresa;
- una cuenta no puede ser miembro de varias empresas salvo decisión explícita del cliente;
- no está cerrada la matriz de permisos de acceso excepcional y temporales;
- no está totalmente validado el comportamiento con permisos cruzados. En la consola ADMIN los cambios de rol/empresa/contrato ya exigen confirmación contextual y motivo, se registran con valores anteriores/nuevos y revocan las sesiones del usuario; esto no constituye auditoría completa de todas las operaciones.

Riesgo:

- crecimiento del sistema sin modelo de alcance definido.

6.7 Auditoría y trazabilidad

Estado: parcial.

Cumple parcialmente:

- eventos de actividad y cambio;

- auditoría de permisos y cambios de usuario;
- motivo en ciertas solicitudes de acceso o URL;
- registro de actividad global.

Brechas:

- faltan eventos de autenticación exitosa/fallida, cierre, revocación y expiración;
- falta historial uniforme de descargas, exportaciones y documentos sensibles;
- falta distinguir claramente creación, actualización, asignación, borrado, desactivación y reactivación;
- no está cerrado el catálogo de acceso a metadatos sensibles ni la retención de auditoría.

Riesgo:

- no se puede responder auditivamente quién consultó qué, cuándo, por qué y con qué alcance.

6.8 Seguridad y aislamiento de datos

Estado: parcialmente implementado, pero no listo para producción.

Cumple parcialmente:

- RLS en tablas con company_id;
- control de acceso en backend;
- separación física por tenant en parte de la base de datos;
- consideración de privilegios mínimos.

Brechas:

- la base de datos del Compose sigue usando modelos de desarrollo, no una configuración de producción real;
- falta validación con roles reales de mínimo privilegio y credenciales producidas para cada servicio;
- faltan pruebas de denegación cruzada entre empresas y contratos;
- no existe un flujo formal de acceso excepcional a documentos sensibles con motivo, tiempo y trazabilidad;
- exportaciones y descargas siguen pendiente de cierre desde el punto de vista de control y auditoría.

Riesgo:

- acceso accidental o no autorizado a datos sensibles.

7. Decisiones pendientes y bloqueadores

Estas son las decisiones, implementaciones y validaciones que todavía deben cerrarse antes de avanzar con una liberación productiva:

- DEC-08: retención, privacidad y auditoría de datos sensibles.
- DEC-10: demostrar mínimo privilegio y aislamiento en API/BD; RLS contractual sigue condicionado a viabilidad y pruebas.
- DEC-11: implementar y validar exportación de datos/archivos, autorización, motivo, auditoría y viabilidad en grandes volúmenes.

- DEC-12: el ciclo de contratos está implementado con validación focalizada; falta aceptación integral y cobertura adicional.
- DEC-13: transferencia de cuenta entre empresas, propuesta pendiente de aprobación del cliente.

Adicionalmente, quedan pendientes:

- decisión concreta de si una cuenta puede pertenecer a varias empresas;
- política formal de exportación/restauración y copias de seguridad;
- política de eliminación de datos y relaciones, separada del ciclo contractual acordado en DEC-12;
- definición de qué elementos no se muestran en dashboards globales por privacidad;
- retención y eliminación de actividades, alertas y exportaciones;
- validación de compatibilidad con entornos de despliegue reales.

8. Riesgos de no cerrar estas brechas

Si no se cierran, la plataforma corre riesgo de:

- presentar resultados engañosos en el dashboard global;
- permitir acceso cruzado por mala interpretación del alcance;
- no responder adecuadamente a auditorías regulatorias o internas;
- crear alertas no confiables o no accionables;
- generar exportaciones o descargas no controladas;
- comprometer la confianza del cliente al manejar datos de otras empresas.

9. Recomendación de avance

Se recomienda tratar estas brechas en este orden:

1. Seguridad y aislamiento: mínimo privilegio, denegación cruzada y acceso excepcional.
2. Auditoría: autenticación, exportaciones, descargas, lecturas sensibles y trazabilidad.
3. Permisos y alcance: usuarios, roles, empresa/contrato y multiempresa.
4. Métricas y salud: definiciones y validación de series.
5. Buscador y dashboard: permisos, universos y tabla de estados objetivos.
6. Cierre documental y validación final con pruebas automatizadas y manuales.

10. Criterio de cierre sugerido

La documentación no debe considerarse cerrada hasta que exista evidencia de:

- criterios de aceptación escritos por requisito;
- pruebas automatizadas o manuales documentadas por dominio;
- validación de permisos y aislamiento con roles reales;
- definición de métricas con universos y ventana temporal;
- evidencia de auditoría para cada operación sensible;
- aprobación del cliente o del dueño del producto para las propuestas pendientes.

11. Conclusión

La consola administrativa ya no se encuentra en una fase totalmente exploratoria. Tiene una base funcional útil y una estructura de permisos y dashboards con valor operativo. Sin embargo, aún no cumple la madurez

esperada para producción porque varias brechas críticas siguen abiertas en seguridad, permisos, auditoría, exportaciones y métricas.

Por ese motivo, el estado correcto del módulo es: funcional y parcialmente validado, pero aún no cerrado para go-live con datos reales.

12. Estructura recomendada para PDF

Para convertir a PDF con Markdown, la estructura más legible es esta:

1. Título y estado
2. Resumen ejecutivo
3. Fuentes de evidencia
4. Matriz de cumplimiento por prioridad
5. Riesgos / bloqueos críticos
6. Recomendaciones y plan de cierre
7. Anexo: requisitos pendientes

Esta estructura permite que el documento se entienda bien en una sola lectura y mantiene claridad para clientes o comité interno.

El resumen siguiente refleja también los ajustes del 13-10-2026; para el detalle vigente de estado y evidencia, prevalecen las secciones 3 a 10 y los documentos enlazados, no las estimaciones históricas.

5.2 Gestión global de empresas

Cumplimiento observado:

- El SRS marca RF-EMP-01 como IV (implementado y validado).
- Se documenta listado de empresas, detalle agregado, estado, industria, estado de cuenta, última actividad y filtros de alcance.
- El detalle incluye perfiles y responsables por contrato. El flujo normal de aprobación se verificó; el rechazo existe, pero requiere validación específica.

Brechas:

- Rechazo y transiciones fuera del flujo normal aún requieren validación específica.
- El acceso y la visualización de información sensible deben seguir controlados.

Conclusión:

- Es la parte más madura del módulo administrativo.

5.3 Buscador global

Cumplimiento observado:

- El buscador existe y cubre empresa, contrato, persona/trabajador, equipo y usuario.
- Los resultados se despliegan desde botones por categoría y el explorador de referencias conserva filtros seleccionables.

Brechas:

- El requisito RF-BUS-01 está en estado PAR.
- Faltan validaciones de permisos por tipo de información, así como cierre integral de criterios.

Conclusión:

- Funcionalidad existente, pero no cerrada ni validada como solución completa.

5.4 Métricas SaaS

Cumplimiento observado:

- Hay métricas de usuarios, clientes, estado de cuenta, MRR y actividad mensuales.
- El backend admin_ops define endpoints y agregados para métricas y tendencias.
- Los indicadores de uso/adopción y los desgloses de usuarios por plan/industria están presentados en Salud de clientes, no en esta vista comercial.

Brechas:

- La documentación alerta que no todo se debe mostrar en el mismo dashboard.
- Debe separarse crecimiento comercial de adopción/actividad.
- Parte de la validación queda parcial.

Conclusión:

- Requiere cierre de definiciones de negocio y de métricas antes de considerarlo maduro.

5.5 Alertas y salud de clientes

Cumplimiento observado:

- Hay soporte de alertas, incidentes, disponibilidad y seguimiento operacional.
- El módulo ops_tasks y la consola interna documentan latidos, disponibilidad y incidentes.
- La interfaz agrupa actividad/adopción y riesgos, con detalle plegable y ayudas informativas; los cálculos y umbrales aún requieren validación.

Brechas:

- El SRS lo deja como ISV/PAR.
- La operación de salud de cliente requiere validación con casos reales y reglas de negocio concretas.

Conclusión:

- Es funcionalmente relevante, pero no cerrada como conjunto operacional de producción.

5.6 Usuarios, roles y permisos

Cumplimiento observado:

- La arquitectura del backend usa dependencias de admin, roles y contexto de organización/empresa.
- Hay documentación de acceso, aprobación de usuarios y aislamiento de permisos.
- Los cambios ADMIN de rol/empresa/contrato requieren confirmación y motivo, registran los valores anteriores/nuevos e invalidan sesiones; la validación de las pruebas específicas sigue pendiente.

Brechas:

- No se certifica la validación completa de permisos entre empresas.
- La documentación indica que “nunca compartir permisos de una empresa con otra” es un requisito crítico, pero la evidencia de cierre completo no está consolidada.

Conclusión:

- La base existe, pero la validación operativa y legal aún no está cerrada.

5.7 Auditoría y trazabilidad

Cumplimiento observado:

- Existe registro de actividad en modelo y endpoints.
- La documentación indica actor, acción, entidad, fecha y resultado como parte de la auditoría.
- Los cambios de permisos registran motivo y valores anteriores/nuevos; la cobertura integral de autenticación, operaciones sensibles y exportaciones sigue pendiente.

Brechas:

- No está cerrada la validación de accesos sensibles y descargas.
- La revisión legal y contractual de privacidad y retención aún está bloqueada en DEC-08.

Conclusión:

- Hay base de trazabilidad, pero no es suficiente para aprobación de producción con datos reales.

5.8 Seguridad y aislamiento de datos

Cumplimiento observado:

- El backend incluye guardas de configuración para producción.
- El arranque valida JWT, RLS, migración y entorno seguro.
- Hay documentación y controles de producción en config y main.

Brechas críticas:

- El SRS lo declara como prioridad P0 y bloqueo de go-live con datos reales.
- Faltan evidencias documentadas para revisar privacidad, retención, responsables y aprobaciones.
- No está validada la política completa de acceso mínimo necesario, exportaciones y descargas.

Conclusión:

- Es la brecha más crítica del proyecto. Sin cerrar esta parte, el sistema no debería exponerse con datos reales.

6. Bloqueos críticos que condicionan la entrega

Bloqueo 1 — DEC-08

El SRS deja explícito que no puede pasar a producción real con datos reales sin documentar:

- revisión legal y contractual
- retención de datos
- responsables
- aprobaciones
- validación de controles

Este punto compone un bloqueo funcional y operativo, no solo documental.

Bloqueo 2 — Seguridad y aislamiento multiempresa

La base de aislamiento existe, pero no se ha cerrado como evidencia formal de cumplimiento. Esto es crítico para clientes, administradores y datos sensibles.

Bloqueo 3 — Validación integral de funciones administrativas

Muchos requerimientos están documentados como ISV, PAR o pendiente. Eso indica que la funcionalidad existe, pero no se ha validado como conjunto integral.

7. Recomendación de cierre

7.1 Enfoque recomendado

1. Cerrar DEC-08 como requisito obligatorio de arquitectura y compliance.
2. Priorizar seguridad y aislamiento antes de más funcionalidad.
3. Completar matriz de requisitos por estado real (IV / ISV / PAR / PEN / COR).
4. Generar evidencia de validación por flujo crítico.
5. Dejar una hoja de ruta con responsables y fechas.

7.2 Prioridades sugeridas

- P0: auditoría, privacidad, retención, roles, contratos y exportaciones sensibles.
- P1: gestión global de empresas, permisos, métricas y buscador.
- P2: mejoras de experiencia y reportes avanzados.

8. Conclusión final

La plataforma está en una etapa avanzada de desarrollo funcional y de arquitectura, con una base sólida en administración global y operaciones. Sin embargo, la evidencia disponible no justifica un despliegue con datos reales ni una entrega “completa” como solución productiva.

El diagnóstico más objetivo es:

- proyecto con buena base técnica y funcional
- aún con brechas importantes de seguridad, auditoría y validación final
- no listo para producción real sin cerrar los bloqueos de DEC-08 y del aislamiento de datos

9. Recomendación para el PDF final

Para mantener el PDF claro y legible:

- Usar títulos H1/H2/H3 con 1 sola idea por sección.

- Preferir tablas breves y bullets directos.
- Mantener las conclusiones al inicio y al final.
- Evitar largas descripciones sin separación por capitulos.
- No incluir código fuente complejo ni rutas largas en el cuerpo principal.

10. Estado de la evidencia

- Evidencia documentada: alta.
- Evidencia de validación funcional completa: parcial.
- Evidencia de producción segura: insuficiente.
- Recomendación: continuar con cierre de gap antes de go-live.